

AETHERIA INFRASTRUCTURE RESEARCH (AIR)

Information Security Risk Assessment Methodology

AIR-ISMS-RSK-001 | Version 1.0 | May 2026

Document Control

Document ID	AIR-ISMS-RSK-001
Version	1.0
Status	Draft — Pending Management Approval
Classification	Confidential
Document Owner	Head of Security & Compliance
Approved By	Chief Executive Officer
Review Cycle	Annual / following significant change or security incident
Last Reviewed	May 2026
Next Review Due	May 2027
Related Documents	AIR-ISMS-AST-001 Asset Inventory AIR-ISMS-RSK-002 Risk Register AIR-ISMS-POL-001 Information Security Policy
Applicable Standard	ISO/IEC 27001:2022 — Clauses 6.1.2 and 6.1.3

1. Purpose

This document defines the methodology AIR uses to identify, analyse, evaluate, and treat information security risks across its ISMS scope. It provides a consistent, repeatable framework that enables risk-based decision-making and ensures that information security controls are proportionate to the risks they address.

This methodology satisfies ISO/IEC 27001:2022 Clause 6.1.2 (Information security risk assessment) and Clause 6.1.3 (Information security risk treatment). All risk assessments conducted within the ISMS must follow this methodology.

2. Scope

This methodology applies to all information assets within the ISMS scope as defined in AIR-ISMS-SCO-001 (ISMS Scope Statement), including:

- Azure cloud infrastructure and associated services (air-prod tenant)
- Microsoft 365, Entra ID, and collaboration platforms
- GitHub Enterprise source code repositories
- Research data repositories (cloud and on-premises, Madrid HQ)
- Managed Windows endpoints (145 corporate devices)
- Infrastructure analysis applications and internal business systems

The methodology applies to all departments, all three office locations (Madrid, Brussels, Riga), and all personnel — including permanent employees, contractors, and external research collaborators with access to AIR systems.

Classification: Confidential

3. Risk Assessment Approach

AIR uses an asset-based risk assessment approach. Risks are identified in relation to specific information assets catalogued in AIR-ISMS-AST-001, evaluated against relevant threat scenarios and vulnerabilities, and scored using a consistent quantitative matrix.

The approach follows four sequential steps:

Step 1 — Asset Identification: Identify the information asset at risk using the Asset Inventory (AIR-ISMS-AST-001). Confirm the asset's classification and owner before proceeding.

Step 2 — Threat and Vulnerability Identification: Identify realistic threats that could exploit vulnerabilities associated with the asset. Reference relevant threat libraries, past incidents, and sector-specific intelligence.

Step 3 — Risk Analysis: Score the inherent risk using the Likelihood and Impact scales in Sections 5 and 6. Calculate the inherent risk score (Likelihood × Impact).

Step 4 — Risk Evaluation and Treatment: Compare the score against AIR's risk acceptance criteria (Section 8). Assign a treatment option and document the residual risk after controls are applied.

4. Threat and Vulnerability Identification

Threats are events or actions that could cause harm to an information asset. Vulnerabilities are weaknesses that make a threat more likely to succeed or cause greater impact. Assessors should consider threats across the following categories:

Threat Category	Examples Relevant to AIR
External Threats	Ransomware, phishing, supply chain compromise, nation-state espionage targeting government-affiliated research, unauthorised access via contractor accounts
Internal Threats	Accidental data loss, shadow IT usage, unsanctioned AI tools processing Restricted data, insider IP exfiltration, incomplete offboarding of staff or contractors
Technical Vulnerabilities	Misconfigured cloud storage, weak or absent MFA, unpatched endpoints, inadequate centralised logging, insecure API key management
Physical Threats	Theft of managed endpoints, unauthorised physical access to Madrid HQ server room, loss of devices at conferences or field locations
Third-Party / Supplier Risks	Supplier breaches affecting integrated platforms, inadequate security controls in contractor environments, undisclosed sub-processors
Compliance and Legal Risks	GDPR breach, failure to meet contractual obligations with government partners, violation of research data sharing agreements

Assessors are not required to use this list exhaustively. The goal is to identify threats that are realistic and relevant to the specific asset under assessment.

5. Likelihood Scale

Likelihood reflects the probability that a threat will successfully exploit a vulnerability given existing controls. Assessors should consider historical incident data, sector threat intelligence, and the current control environment when assigning a score.

Score	Level	Description
1	Rare	Unlikely to occur. No known precedent in comparable organisations. Expected less than once in five years.

Classification: Confidential

2	Unlikely	Could occur but not expected. Occurs occasionally in comparable organisations. Expected once in two to five years.
3	Possible	Might occur. Precedent exists within the research or public-sector context. Expected once every one to two years.
4	Likely	Expected in some circumstances. Has occurred in AIR or similar organisations recently. Expected once per year or more.
5	Almost Certain	Expected in most circumstances. Known active exploitation or high-frequency threat. Expected multiple times per year.

6. Impact Scale

Impact reflects the potential consequence to AIR if a risk event occurs. Assessors should evaluate across four dimensions (confidentiality, integrity, availability, and operational) and select the highest applicable score.

Score	Level	Confidentiality	Integrity	Availability	Operational
1	Negligible	Minor internal disclosure; no external consequence	Minor data quality issues; quickly corrected	Disruption under one hour; no service breach	No meaningful operational impact
2	Minor	Limited disclosure within AIR; no regulatory threshold	Recoverable errors corrected within 24 hours	Disruption one to eight hours; no contractual breach	Minor process delays within one department
3	Moderate	Disclosure to unauthorised external parties; regulatory notification may be required	Significant errors requiring formal correction and partner notification	Disruption one to three days; research programme delays	Operational disruption affecting one department or office location
4	Significant	Regulatory breach or government contractual violation; formal investigation likely	Serious data corruption affecting research outputs or government deliverables	Disruption three to seven days; active government contracts affected	Multi-department failure; significant reputational or financial consequence
5	Severe	Public exposure of restricted data; legal action, contract termination, or loss of licence	Irreversible loss or deliberate falsification of research data or AI model integrity	Disruption exceeding seven days; critical deliverables missed	Organisation-wide operational failure; existential financial or reputational harm

7. Risk Scoring

The inherent risk score is calculated as:

$$\text{Inherent Risk Score} = \text{Likelihood (1–5)} \times \text{Impact (1–5)} = \text{Score range: 1 to 25}$$

After controls are applied, the residual risk score is calculated using the same formula, reflecting reduced likelihood or impact. Both scores are recorded in the Risk Register (AIR-ISMS-RSK-002).

7.1 Risk Level Classification

Score Range	Risk Level	Required Action
1 – 4	Low	Risk is within tolerance. Accept with documented rationale and periodic monitoring.

Classification: Confidential

5 – 9	Medium	Risk treatment plan required. Risk owner assigned. Treatment target: 180 days.
10 – 16	High	Priority treatment required. Senior risk owner assigned. Target: 90 days. Reported to Head of Security & Compliance monthly.
17 – 25	Critical	Immediate escalation to Executive Leadership. Target: 30 days. Interim controls must be implemented immediately.

7.2 Risk Heat Map (5 × 5 Matrix)

The matrix below shows inherent risk scores by Likelihood (rows) and Impact (columns). Green = Low | Yellow = Medium | Orange = High | Red = Critical

L \ I		1 Negligible	2 Minor	3 Moderate	4 Significant	5 Severe
				← IMPACT →		
5 — Almost Certain		5	10	15	20	25
4 — Likely		4	8	12	16	20
3 — Possible	↑ L I K E L I H O O ↓	3	6	9	12	15
2 — Unlikely		2	4	6	8	10
1 — Rare		1	2	3	4	5

8. Risk Appetite and Acceptance Criteria

AIR's risk appetite is set and approved by Executive Leadership on an annual basis, differentiated by asset classification and risk domain.

Risk Domain	Appetite	Acceptance Criteria
Restricted Data Assets (PA-001 through PA-006)	Low	No risk above score 4 accepted without a treatment plan and sign-off from the Head of Security & Compliance.
Regulatory and Contractual Compliance (GDPR, government research obligations)	Low	No compliance risk accepted regardless of score. All compliance risks require treatment.
Operational Continuity (research delivery, system availability)	Medium	Risks scoring 9 or below may be accepted with documented rationale and annual review.
Reputational Risk (public trust, partner relationships)	Low	No reputational risk above score 6 accepted without senior leadership sign-off.
General Internal Systems (Internal-classified assets, operational tooling)	Medium	Risks scoring 9 or below may be tolerated with standard monitoring. Risks at 10 or above require a treatment plan.

The ISMS-wide residual risk acceptance threshold is a score of 9 or below. Any risk with a residual score of 10 or above must have an approved, time-bound treatment plan before it can remain in an accepted state.

Classification: Confidential

9. Risk Treatment Options

For each risk exceeding the acceptance threshold, the risk owner must select one of the following treatment options. The selected option and rationale must be recorded in the Risk Register (AIR-ISMS-RSK-002).

Option	Description
Treat (Mitigate)	Implement or strengthen controls to reduce likelihood or impact. Most common option. Examples: enabling MFA, encrypting storage containers, improving offboarding procedures.
Tolerate (Accept)	Accept the risk within AIR's documented risk appetite. Requires written justification and approval from the Head of Security & Compliance. Not applicable above the acceptance threshold without executive sign-off.
Transfer (Share)	Shift financial or operational consequence to a third party. Examples: cyber insurance, contractual liability clauses with suppliers, SLA-backed cloud service agreements. Note: accountability cannot be fully transferred.
Terminate (Avoid)	Discontinue the activity, process, or system generating the risk. Appropriate when the risk cannot be reduced to an acceptable level and the activity is non-essential. Example: decommissioning an unsupported research data system.

10. Roles and Responsibilities

Role	Responsibility in Risk Process
Executive Leadership	Approves risk appetite annually. Reviews and accepts all Critical risks. Receives quarterly risk summary from Head of Security & Compliance.
Head of Security & Compliance	Owns this methodology. Facilitates risk assessments. Maintains the Risk Register. Escalates Critical and High risks. Coordinates annual risk assessment cycle.
Department Heads / Asset Owners	Act as risk owners for risks in their area. Implement agreed treatment plans. Report progress to Head of Security & Compliance.
IT Operations	Provides technical input on vulnerabilities and control effectiveness. Implements technical risk treatment actions as directed.
Legal & Partnerships	Advises on regulatory and contractual risk implications. Reviews risks touching GDPR, government agreements, or third-party data obligations.
All Employees and Contractors	Report potential risks, incidents, or control weaknesses via the designated reporting channel. Complete mandatory security awareness training annually.

11. Review and Update Cycle

Risk assessments are conducted and reviewed on the following schedule:

Review Type	Frequency	Owner	Notes
Full Risk Assessment	Annual	Head of Security & Compliance	May of each year, aligned to ISMS management review
Risk Register Review	Quarterly	Head of Security & Compliance	February, May, August, November
Ad Hoc: New Asset or System	Within 30 days of change	Relevant Asset Owner	Triggered by new system introduction or significant change
Ad Hoc: Post-Incident	Within 10 working days	Head of Security & Compliance	Triggered by any incident classified Medium severity or above
Ad Hoc: New Partnership	Prior to contract execution	Head of Legal & Partnerships	Triggered by new government or external

Classification: Confidential

			research partner agreement
--	--	--	----------------------------

12. Link to Risk Register

All risks identified through this methodology are recorded in the Risk Register (AIR-ISMS-RSK-002), the single authoritative source of all active information security risks. Each entry references:

- The relevant primary asset from the Asset Inventory (AIR-ISMS-AST-001)
- The threat scenario and vulnerability that gives rise to the risk
- The inherent risk score (pre-control)
- Existing controls currently in place
- The selected treatment option and responsible owner
- The residual risk score (post-control)
- The target resolution date and current status

The Risk Register is reviewed at each quarterly security review meeting and updated following any significant change to the risk landscape, control environment, or organisational structure.